

CISSP Printable Practice Exam 16 - Domain 8 - Software Development Security

Practice Exam 02 - Domain 8

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP2-136)

Scenario: A public benefits agency is beginning a Waterfall development project. Its requirements document says only that the application must protect confidential information, and the design phase is scheduled to begin next week.

What should the security architect do FIRST?

- A. Schedule a penetration test after implementation and use its findings to define the missing requirements.
- B. Let each developer interpret the policy statement and document the selected controls in source-code comments.
- C. Convert applicable risks and policies into measurable security requirements, acceptance criteria, and requirements traceability before design approval.
- D. Defer security requirements until user acceptance testing reveals which functions handle confidential information.

Question 2 (CISSP2-137)

Scenario: A logistics company wants to improve software security maturity. Different teams use unrelated checklists, metrics are unavailable, and leaders disagree about which process weaknesses create the greatest business risk.

Which action is the BEST starting point for a sustainable improvement program?

- A. Assess current capabilities against a selected maturity model, define the desired state, and prioritize gaps according to business risk.
- B. Mandate the highest maturity level for every team before documenting existing development processes.
- C. Purchase additional testing tools and use the number of generated findings as the maturity score.
- D. Standardize the easiest existing checklist without determining whether it addresses the organization's principal risks.

Question 3 (CISSP2-138)

Scenario: An insurer plans to add a partner-facing interface to an internally used claims application. The change introduces external data flows and a new category of personal information, but the project manager considers it a routine feature release.

What is the security manager's MOST appropriate response?

- A. Approve the release because the underlying application previously passed its security evaluation.
- B. Require the partner to accept all application risk because the new interface will be used externally.
- C. Repeat every historical test regardless of whether the affected controls or data flows changed.
- D. Conduct a security impact analysis and update the risk assessment, control validation, and authorization evidence as the change requires.

Question 4 (CISSP2-139)

Scenario: A research team wants to demonstrate a new customer analytics concept in three weeks. To save time, it proposes using a copy of production data and connecting the

prototype directly to an internal production service. Executives say the demonstration may later become a supported application.

Which approach BEST balances rapid learning with secure development?

- A. Permit unrestricted production access because the prototype will initially have few users.
- B. Use minimized or synthetic data in an isolated environment, define prototype security constraints, and require full lifecycle review before any production transition.
- C. Treat the prototype as production-ready if its functional demonstration succeeds within the deadline.
- D. Prohibit prototyping and require the team to complete the entire production release process before testing the concept.

Question 5 (CISSP2-140)

Scenario: A regional utility is preparing a normal release that changes authorization logic in a customer portal. The change advisory group must decide whether the release is ready for production.

Which TWO items provide the MOST relevant security evidence for the approval decision?

Select 2 of the 5 options below.

- A. The number of lines of code written by each developer during the release.
- B. A documented security impact analysis identifying affected assets, threats, and controls.
- C. A statement that the release compiled successfully on the lead developer's workstation.
- D. A list of unrelated defects deferred from older versions of the application.
- E. Results of risk-appropriate testing plus an approved deployment and rollback plan.

Question 6 (CISSP2-141)

Scenario: A game studio discovers that an unapproved integrated development environment extension copied portions of proprietary source code to an external service. Developers currently install extensions without review because they improve productivity.

Which control would BEST reduce recurrence while supporting legitimate development needs?

- A. Maintain an approved extension catalog, validate source and permissions, centrally enforce installation policy, and monitor exceptions.
- B. Permit any digitally signed marketplace extension because the signature establishes that its behavior is safe.
- C. Rely on endpoint data loss prevention rules while allowing developers to install extensions from any source.
- D. Review an extension's source and permissions only after monitoring identifies suspicious outbound activity.

Question 7 (CISSP2-142)

Scenario: A community platform stores user profile text in a database. When another user views a profile, the application inserts that text directly into an HTML page, allowing stored script content to execute in the viewer's browser.

What is the BEST primary remediation?

- A. Encrypt the profile table so scripts cannot be read directly from database storage.
- B. Require longer passwords for users who are permitted to edit profile text.
- C. Apply context-appropriate output encoding and safe templating, supplemented by

server-side input validation where suitable.

D. Hide the profile editing link from users whose browsers do not support client-side scripting.

Question 8 (CISSP2-143)

Scenario: A laboratory scheduling application returns database statements, internal file paths, and stack traces to users when requests fail. Developers rely on these messages to troubleshoot production incidents.

How should the development team correct this weakness?

- A. Continue displaying the details but add a notice telling users not to share error messages.
- B. Suppress all error records so internal implementation details are not retained anywhere.
- C. Send stack traces only to users who confirm that they work for the organization.
- D. Return generic client messages with correlation identifiers and record detailed diagnostics in protected, access-controlled logs.

Question 9 (CISSP2-144)

Scenario: A document service accepts a user-supplied URL and instructs its server to retrieve the referenced file. Testing shows that crafted URLs can cause requests to internal administration endpoints and cloud instance metadata addresses.

Which design change would MOST effectively reduce this risk?

- A. Reject hostnames on a block list of currently known internal services while allowing all other destinations.
- B. Restrict destinations and protocols with server-side allow lists, safely resolve and validate addresses, and block access to internal and metadata ranges.
- C. Route requests through an outbound proxy that records destinations but does not enforce a destination policy.
- D. Validate the initially resolved address but permit redirects without applying the validation again.

Question 10 (CISSP2-145)

Scenario: An open collaboration project runs proposed code changes from external contributors on a persistent continuous integration worker. The worker has network access to internal services and holds credentials used for production releases.

What is the BEST way to reduce the resulting development ecosystem risk?

- A. Run untrusted jobs in ephemeral isolated workers without production secrets or unnecessary internal access, and use a separate trusted release stage.
- B. Keep the persistent worker and limit the production credential to the permissions normally required for a release.
- C. Scan proposed code before execution while retaining the worker's internal connectivity and production secrets.
- D. Run external contributions under a separate operating system account on the same persistent worker with access to the same network and secrets.

Question 11 (CISSP2-146)

Scenario: A pharmacy software team has extensive automated functional tests. It wants security findings that combine knowledge of executing code paths, data flow, and runtime behavior without waiting for a separate end-of-cycle scan.

Which testing technique BEST fits this requirement?

- A. Static application security testing performed after each build without executing the application.
- B. Dynamic application security testing that probes exposed interfaces without internal runtime instrumentation.
- C. Interactive application security testing through instrumentation while the functional tests exercise the application.
- D. A manual penetration test conducted against the completed application at the end of the release cycle.

Question 12 (CISSP2-147)

Scenario: A transit authority is evaluating commercial software for a system expected to remain in service for eight years. The application will support a critical business process and cannot be replaced quickly if the supplier ends support.

Which TWO factors are MOST important to evaluate before acquisition? Select 2 of the 5 options below.

- A. Documented support and end-of-life plans, including expected maintenance for the required service period.
- B. A point-in-time penetration test summary for a demonstration version with no commitment to address future findings.
- C. A current security certification that does not define product support, update, or vulnerability handling obligations.
- D. Contractual vulnerability notification, remediation, update, and security incident obligations.
- E. A one-time source-code review performed before deployment with no provision for later versions or maintenance releases.

Question 13 (CISSP2-148)

Scenario: A vulnerability is disclosed in a common compression component. An industrial company uses dozens of internally developed and acquired applications, and the component may be included indirectly within other packages.

Which capability would MOST improve the company's ability to determine its exposure quickly?

- A. A list of application owners that omits component and version information.
- B. A maintained software bill of materials linked to deployed versions and including direct and transitive dependencies.
- C. An external vulnerability scan of application endpoints that cannot identify components embedded inside packages.
- D. Supplier statements that deployed products are current without an inventory of included component versions.

Question 14 (CISSP2-149)

Scenario: An API automatically maps every property in a client request to an internal account object. A tester adds an undocumented privilege property to an otherwise valid profile update and changes the account's role.

Which remediation MOST directly addresses the coding weakness?

- A. Document the privilege property so clients know that it should not be changed.
- B. Require the tester to use a longer access token when sending profile updates.
- C. Rename sensitive internal properties so ordinary clients are less likely to guess them.
- D. Bind only explicitly permitted request fields and enforce server-side authorization

for every sensitive property change.

Question 15 (CISSP2-150)

Scenario: A records-management product accepts complex files from untrusted external parties. Reviewers are concerned that unusual combinations of lengths, headers, and nested structures could trigger crashes or unsafe parser behavior that ordinary test cases do not cover.

Which assessment method would BEST target this concern?

- A. Perform a manual source review focused on documented parsing paths and expected file structures.
- B. Run load tests using a large collection of well-formed files that follow the published specification.
- C. Use coverage-guided fuzz testing with malformed and mutated inputs while monitoring for crashes and anomalous behavior.
- D. Repeat functional acceptance tests with representative valid files and compare the resulting records.

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP2-136) - Correct: C

In a sequential lifecycle, measurable security requirements and acceptance criteria should be established before design so they can guide architecture, implementation, and testing. A late penetration test can validate controls but is not a substitute for requirements. Individual interpretations create inconsistency, and waiting for acceptance testing makes fundamental security defects costly to correct.

Question 2 (CISSP2-137) - Correct: A

A maturity initiative needs an evidence-based current-state baseline, a business-aligned target, and prioritized gaps. Declaring the highest level without understanding existing processes is unrealistic. Tool output alone does not measure institutionalized capability, and adopting the easiest checklist may standardize practices that do not address material risk.

Question 3 (CISSP2-138) - Correct: D

New exposure and data use can alter the system's risk profile, so the organization should analyze the change and reassess affected controls before release. Prior evaluation does not automatically cover materially different data flows. Risk accountability cannot simply be transferred to the partner, while repeating every test without scoping wastes effort and may still miss change-specific risk.

Question 4 (CISSP2-139) - Correct: B

Isolation, safe data, and explicit constraints reduce experimentation risk, while a defined transition gate prevents temporary shortcuts from entering production unnoticed. Few users do not eliminate data or service risk. Functional success is not security assurance, and banning prototypes sacrifices legitimate learning when proportionate controls can contain exposure.

Question 5 (CISSP2-140) - Correct: B, E

The impact analysis explains how the authorization change affects risk, while relevant test results and controlled deployment and rollback plans show whether the change can be introduced safely. Code volume is not evidence of security. A local compilation demonstrates little about control effectiveness, and unrelated historical defects do not establish this release's readiness.

Question 6 (CISSP2-141) - Correct: A

A governed catalog with provenance, permission review, technical enforcement, and exception monitoring addresses extension supply-chain risk without eliminating useful tools. A signature establishes origin and integrity, not safe behavior. Data loss prevention is only a partial safeguard, and reviewing an extension after suspicious activity is reactive rather than preventive.

Question 7 (CISSP2-142) - Correct: C

Context-aware output encoding prevents stored untrusted text from being interpreted as executable markup or script, and safe templating helps apply that control consistently. Input validation can provide defense in depth but should not replace encoding at the output context. Database encryption, password length, and hidden interface links do not neutralize malicious content rendered to an authorized viewer.

Question 8 (CISSP2-143) - Correct: D

Generic responses prevent disclosure of internal structure, while correlation identifiers

connect user reports to detailed server-side logs available to authorized support staff. A warning does not protect exposed data. Eliminating logs impairs investigation, and employment status alone does not establish a user's operational need for sensitive diagnostic details.

Question 9 (CISSP2-144) - Correct: B

Server-side destination controls, robust parsing and resolution, and explicit blocks for internal and metadata addresses constrain where the trusted server can connect. A block list can miss aliases and newly exposed destinations. Logging without enforcement detects but does not prevent access, and redirects must be revalidated because they can resolve to a forbidden target after the initial check.

Question 10 (CISSP2-145) - Correct: A

Ephemeral isolation limits persistence and lateral movement, removal of production secrets enforces least privilege, and a separate trusted release stage prevents unreviewed code from inheriting deployment authority. Narrowing a release credential does not justify exposing it to untrusted jobs. Scanning is valuable but cannot replace containment, and a separate account on the same privileged worker may still reach shared secrets and internal services.

Question 11 (CISSP2-146) - Correct: C

IAST instruments the application during execution and can correlate runtime behavior with code and data flow while existing functional tests exercise relevant paths. SAST provides code insight without runtime observation, while DAST observes exposed behavior without the requested internal instrumentation. An end-of-cycle penetration test provides useful assurance but not continuous feedback during the automated functional tests.

Question 12 (CISSP2-147) - Correct: A, D

Support and end-of-life plans reveal whether the product can remain maintainable across the intended service period, while contractual security obligations establish how vulnerabilities, updates, and incidents will be handled. Point-in-time tests, certifications, and code reviews may provide useful evidence about one version, but without ongoing commitments they do not manage security across the required eight-year lifecycle.

Question 13 (CISSP2-148) - Correct: B

A current SBOM tied to deployed versions provides the component and dependency relationships needed to identify affected software, including indirect inclusion. Owner lists help coordination but cannot establish technical exposure without component data. External scans may not reveal packaged dependencies, and general supplier statements do not provide the component-version detail needed for rapid correlation.

Question 14 (CISSP2-149) - Correct: D

Explicit field allow-listing prevents arbitrary client properties from being bound to trusted objects, and authorization checks protect legitimate sensitive update paths. Documentation and obscure names do not enforce security. Token length relates to credential strength, not whether an authenticated client may modify a privileged field.

Question 15 (CISSP2-150) - Correct: C

Fuzz testing systematically exercises unexpected input combinations and is well suited to finding parser crashes, boundary errors, and unsafe behavior outside ordinary functional cases. Manual review can help but may miss complex input interactions. Load and functional tests using valid files assess performance and expected behavior rather than resilience to malformed structures.